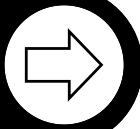


seKUrity

XSS

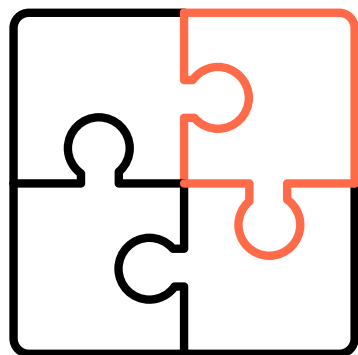
Cross Site Scripting

컴퓨터공학과 25학번 유수민



XSS

Cross Site Scripting



01 HTTP header

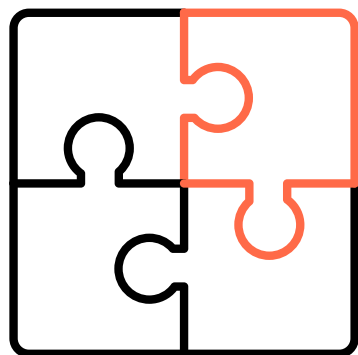
02 SOP 정책

03 CORS 정책

04 쿠키 및 세션

XSS

Cross Site Scripting



05

XSS

06

XSS 공격 분류

07

XSS 공격에 중요한 점

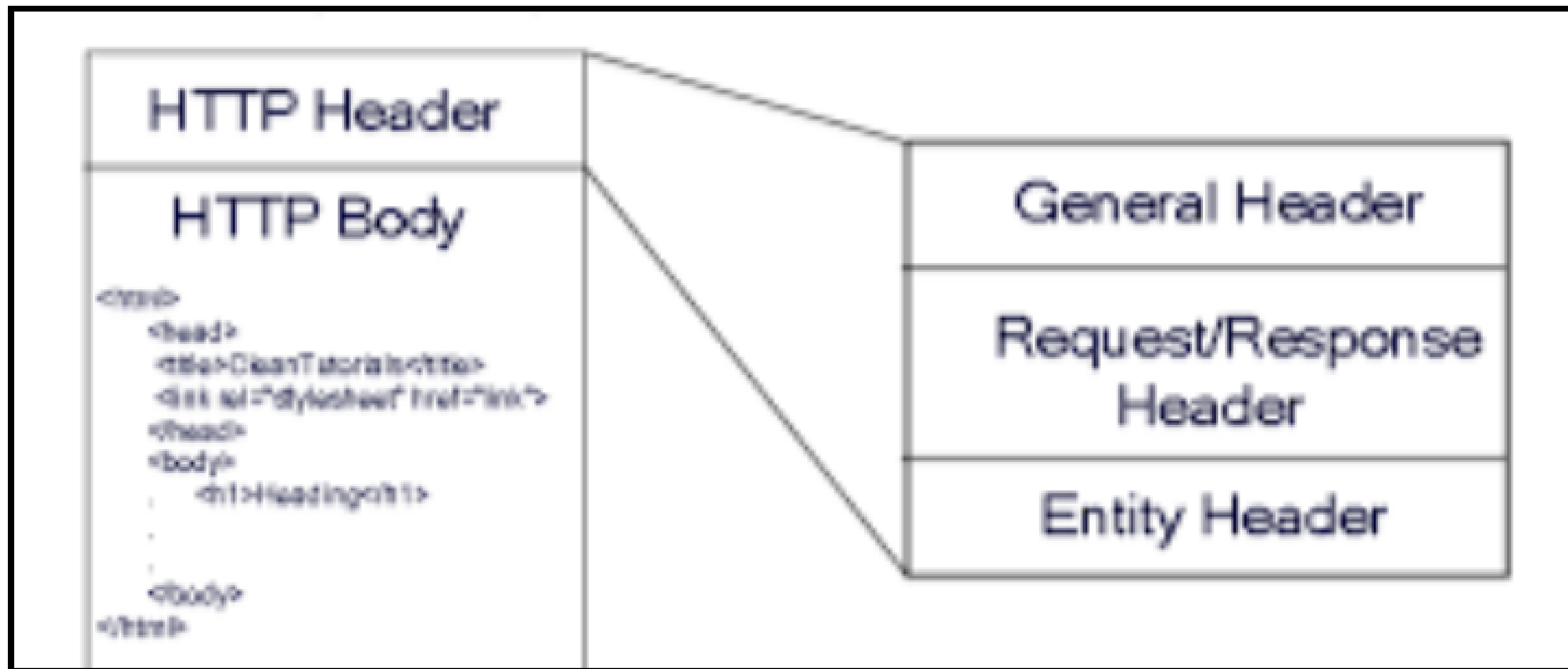
08

XSS 공격의 파급력

09

XSS 공격의 조치 방안

HTTP header



HTTP header



HTTP header(헤더)란

웹 브라우저와 서버 간의 통신 방법인 HTTP 통신 메시지에서 메타데이터를 담고 있는 부분

HTTP header

General header

요청과 응답 모두 사용되는 헤더 필드

Request header

요청 클라이언트에 대한 추가적인 정보로 사용되는 헤더 필드

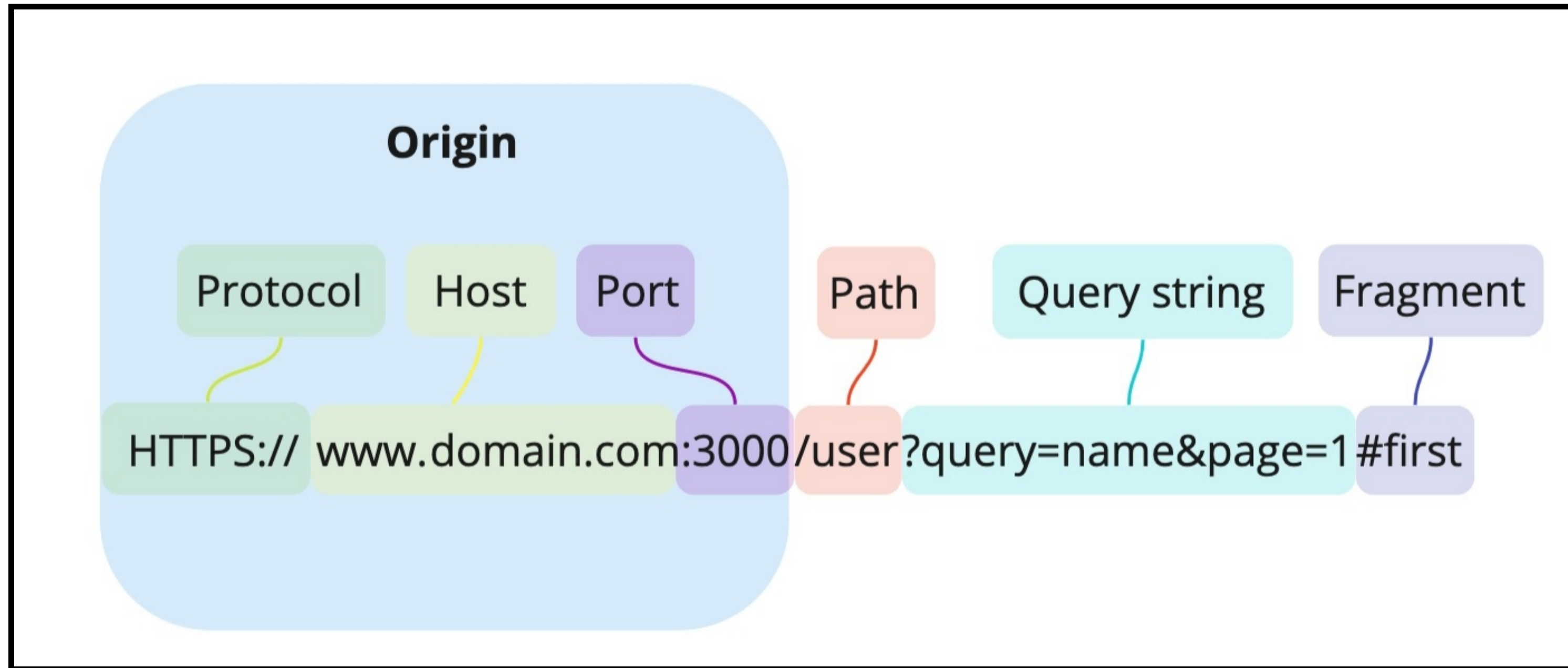
Response header

응답 서버에 대한 추가적인 정보로 사용되는 헤더 필드

Representation header

메시지 본문으로 전송된 데이터에 대한 추가적인 정보

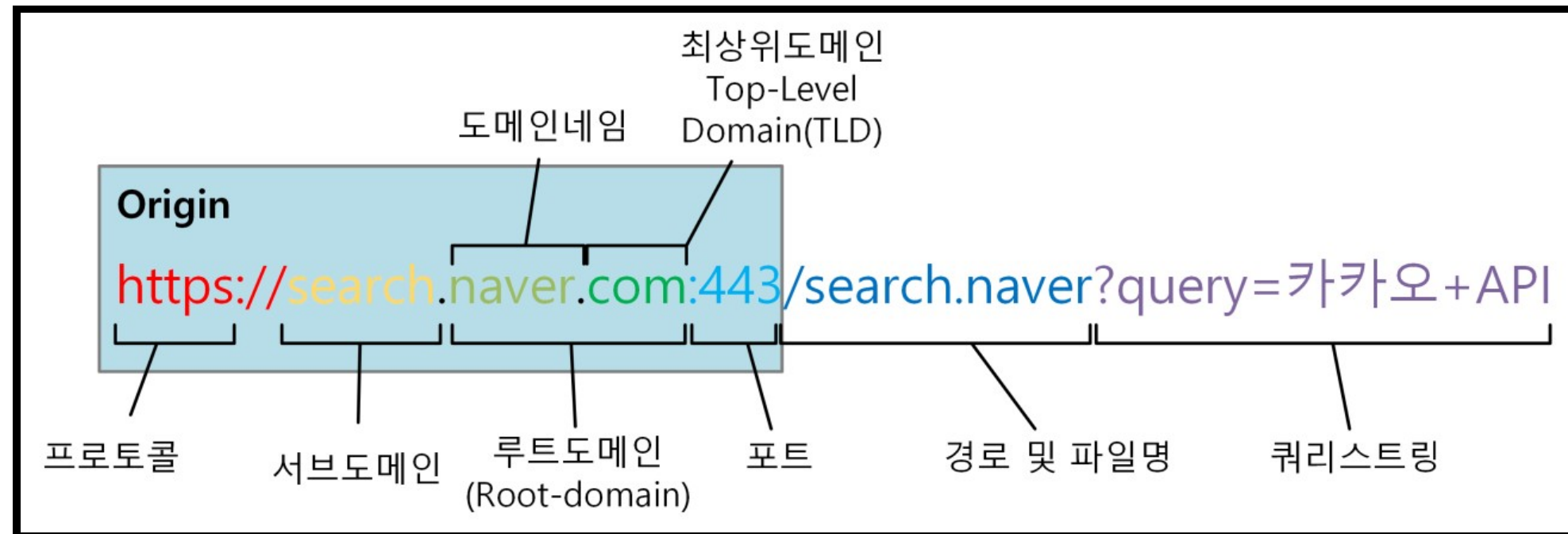
SOP 정책



SOP 정책



SOP 정책이란



같은 Origin에서만 리소스를 공유할 수 있다는 규칙을 가진 정책

이 정책을 적용하면 XSS(Cross Site Scripting)등과 같은 공격으로부터 방어할 수 있음

CORS 정책



CORS

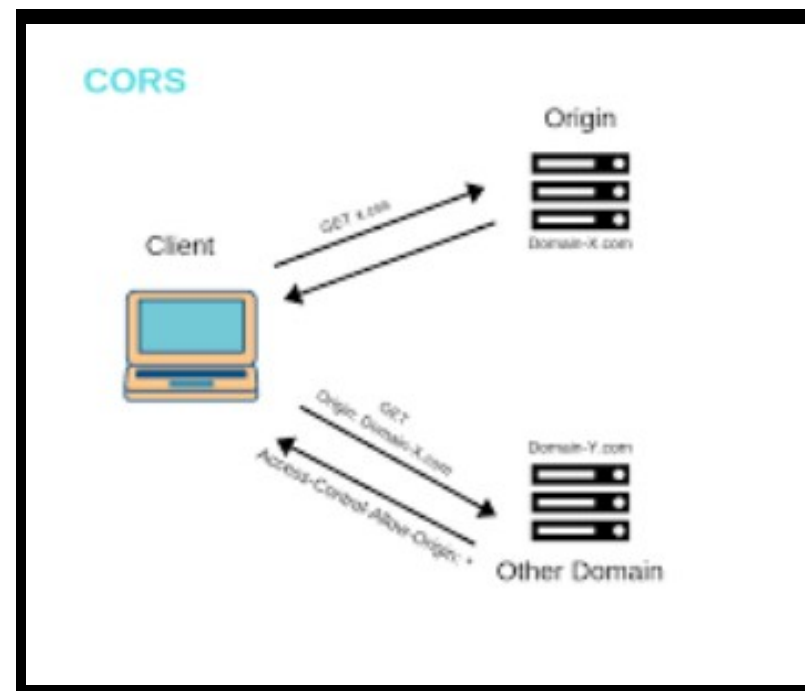
Cross-origin-resource-sharing

Access to XMLHttpRequest at 'https://localhost:44300/api/route/' from origin 'http://localhost:3000' has been blocked by CORS policy: Response to preflight request doesn't pass access control check: No 'Access-Control-Allow-Origin' header is present on the requested resource.

CORS 정책



CORS 정책이란



웹 브라우저에서 기본적으로 막는 다른 출처의 자원 접근을, 서버가 특정 출처를 허용하도록 헤더를 통해 제어하는 보안 메커니즘

쿠키 및 세션



Cookie

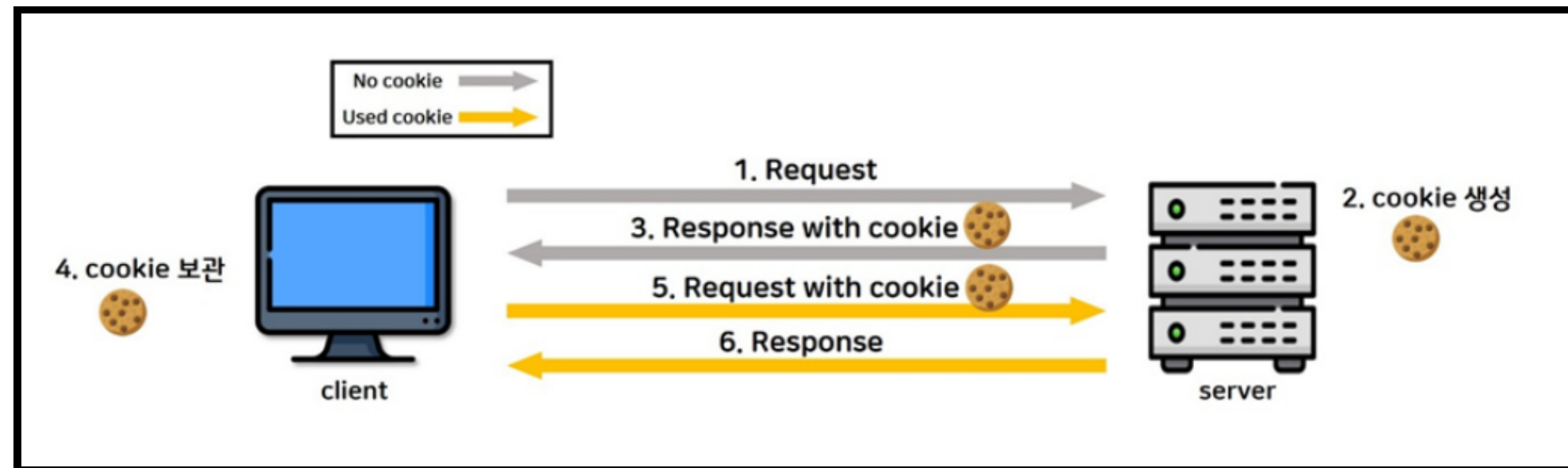


Session

쿠키



쿠키란

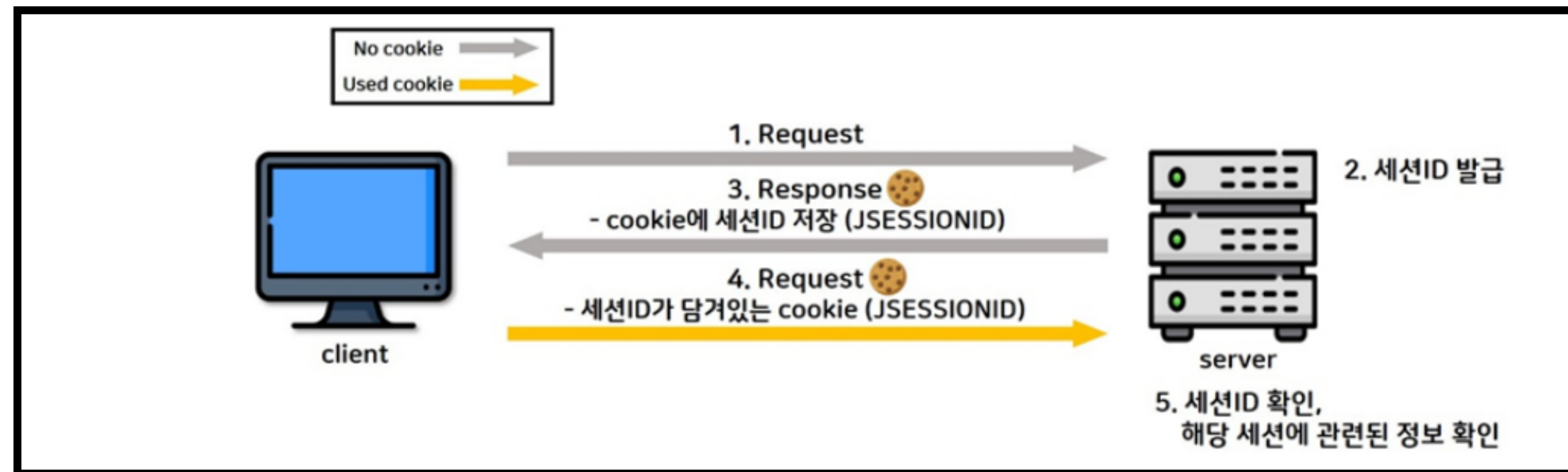


웹 사이트가 사용자의 정보를 저장하기 위해 사용자의 디바이스에 저장하는 작은 텍스트 파일

세션



세션이란



인터넷 서버에서 인터넷 브라우저(사용자)와 상호작용할 때 생성되는 일시적인 상태정보
+ 서버에만 저장함

XSS



XSS

Cross-site Scripting

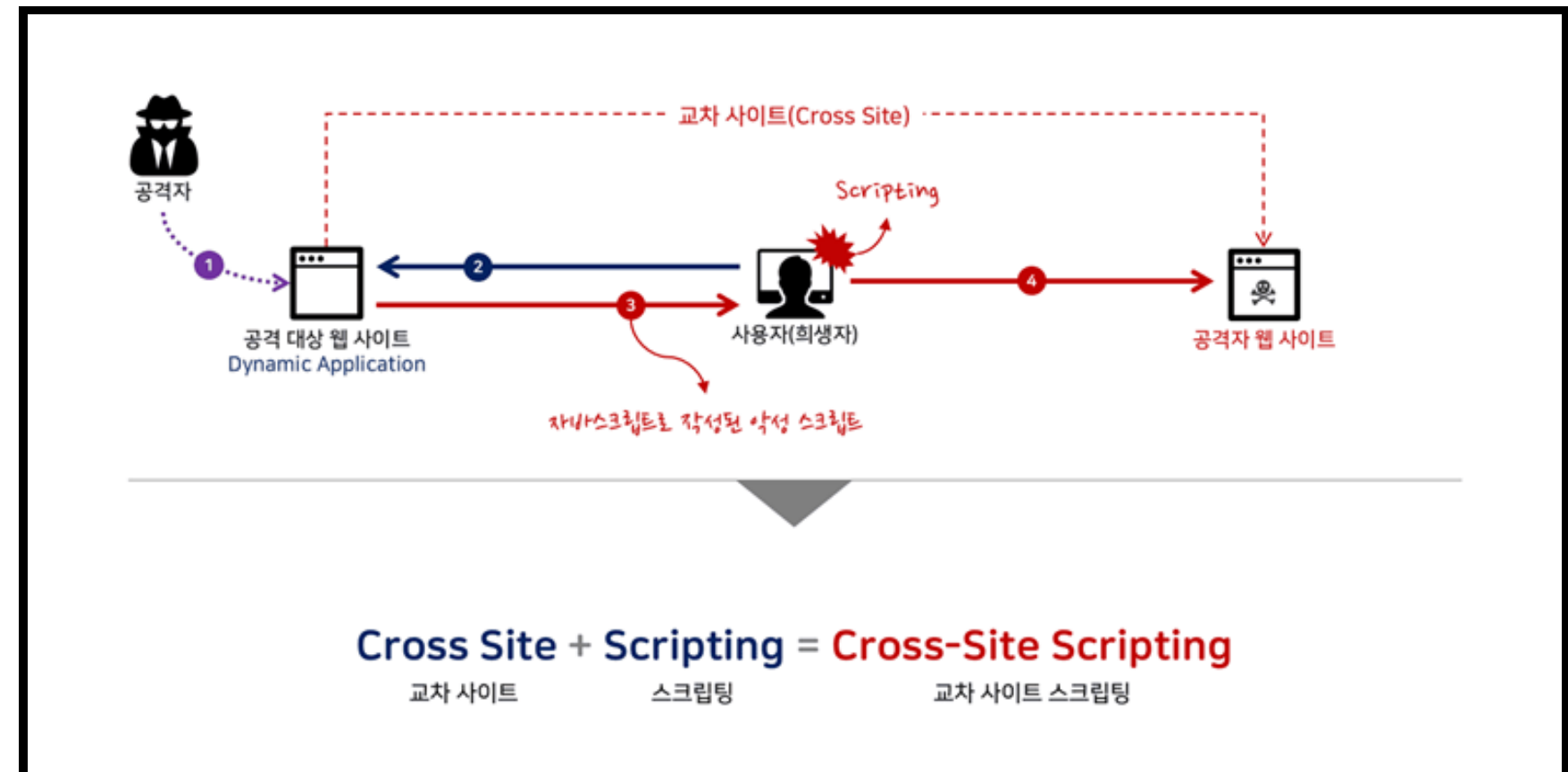
XSS



XSS란

Cross Site Scripting (교차 사이트 스크립팅)

웹 사이트의 관리자가 아닌 악의적인 목적을 가진 제 3자가 악성 스크립트를 삽입하여
의도하지 않은 명령어를 실행시키거나 세션 등을 탈취할 수 있는 취약점



XSS 공격 분류



- **Stored XSS (저장형 크로스 사이트 스크립팅)**
- **Reflected XSS (반사형 크로스 사이트 스크립팅)**
- **DOM Based XSS (DOM 기반 크로스 사이트 스크립팅)**

Stored XSS



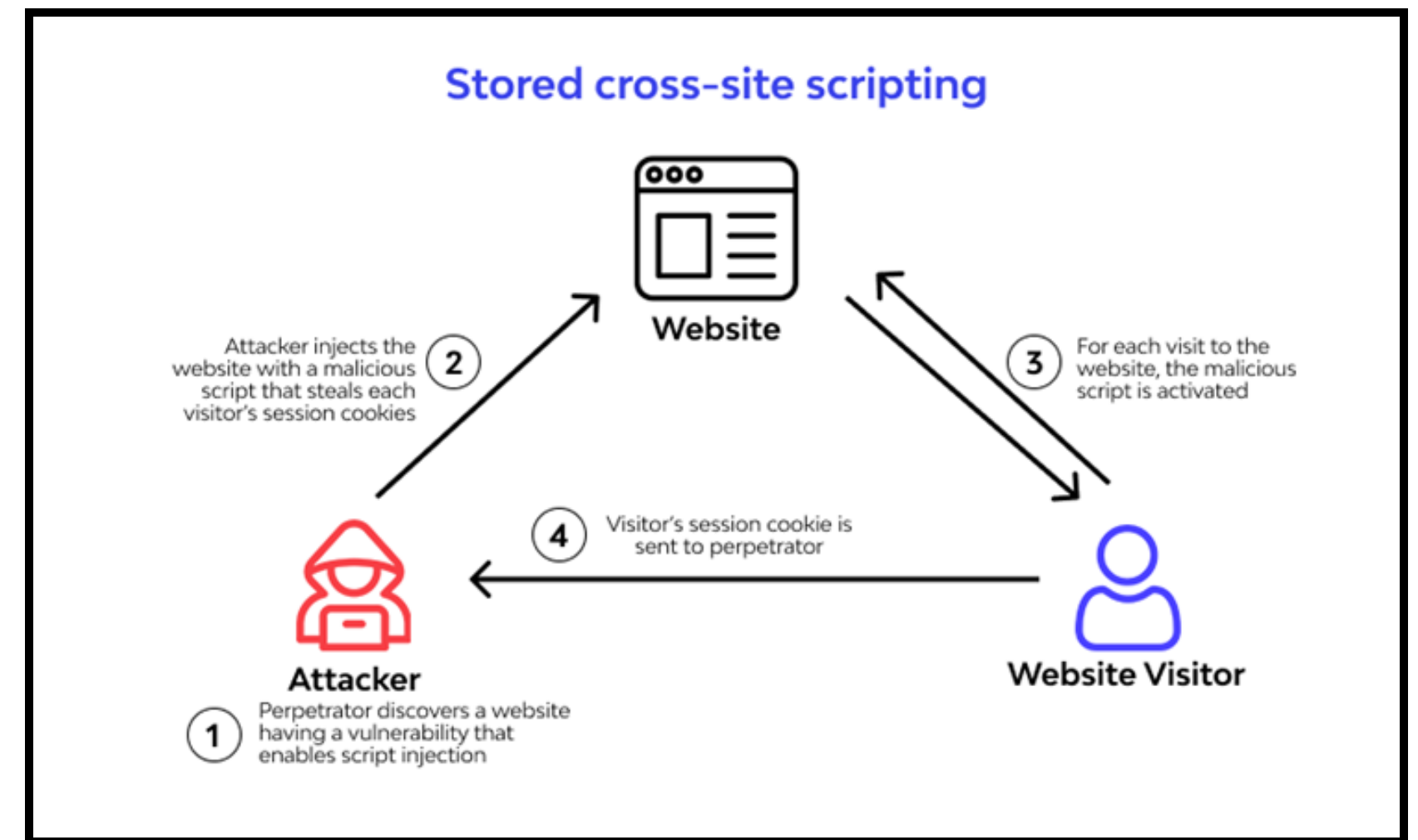
Stored XSS(저장형 크로스 사이트 스크립팅)란

XSS 취약점이 있는 웹 서버에

악성 스크립트를 입력하여 서버에 저장해두고

방문자가 해당 페이지를 읽는 순간

방문자의 브라우저를 공격하는 방식



Stored XSS



Stored XSS(저장형 크로스 사이트 스크립팅)란

에 삽입된 페이지 내용:

PHPSESSID:
sbAzPGd4GliRW4MeHToUkx7XSKhHjw1euwOsqXxtM7YVbDDz9lykk
4TSkH3Zmp0F5kQax
kaiYhNxrnutwavkXgwr9br5EKICfZITWDNQ8Rx31u1I5KLN94o%2B8u
LOHOLoWs7Ko8bGPIGmw8n%2FN
hJmTKWLrfsCfcqj408M3C1fqljz6sSOxBnXk70OAMV0Qoxz1PwV8Cc
PjkPGpzKbtbv2KMNCJ%2FbDUz
g2ZGZK8JEs0W4OvhVnIKUDiXuWSpfHESRcdzkl4BVvxiRI979aZOMZa
7rW3vJjv8hQ%3D%3D--see3SxDojOTAGqMI--
VcFwicVaiuiu5Q7kodnzuw%3D%3D

확인

공격자가 게시글이나 댓글에 악성 스크립트를 심어 데이터베이스에 저장되면,
다른 사용자가 그 페이지를 볼 때 스크립트가 자동 실행되어
세션, 쿠키, 토큰 등이 탈취로 이어지는 공격

Reflected XSS



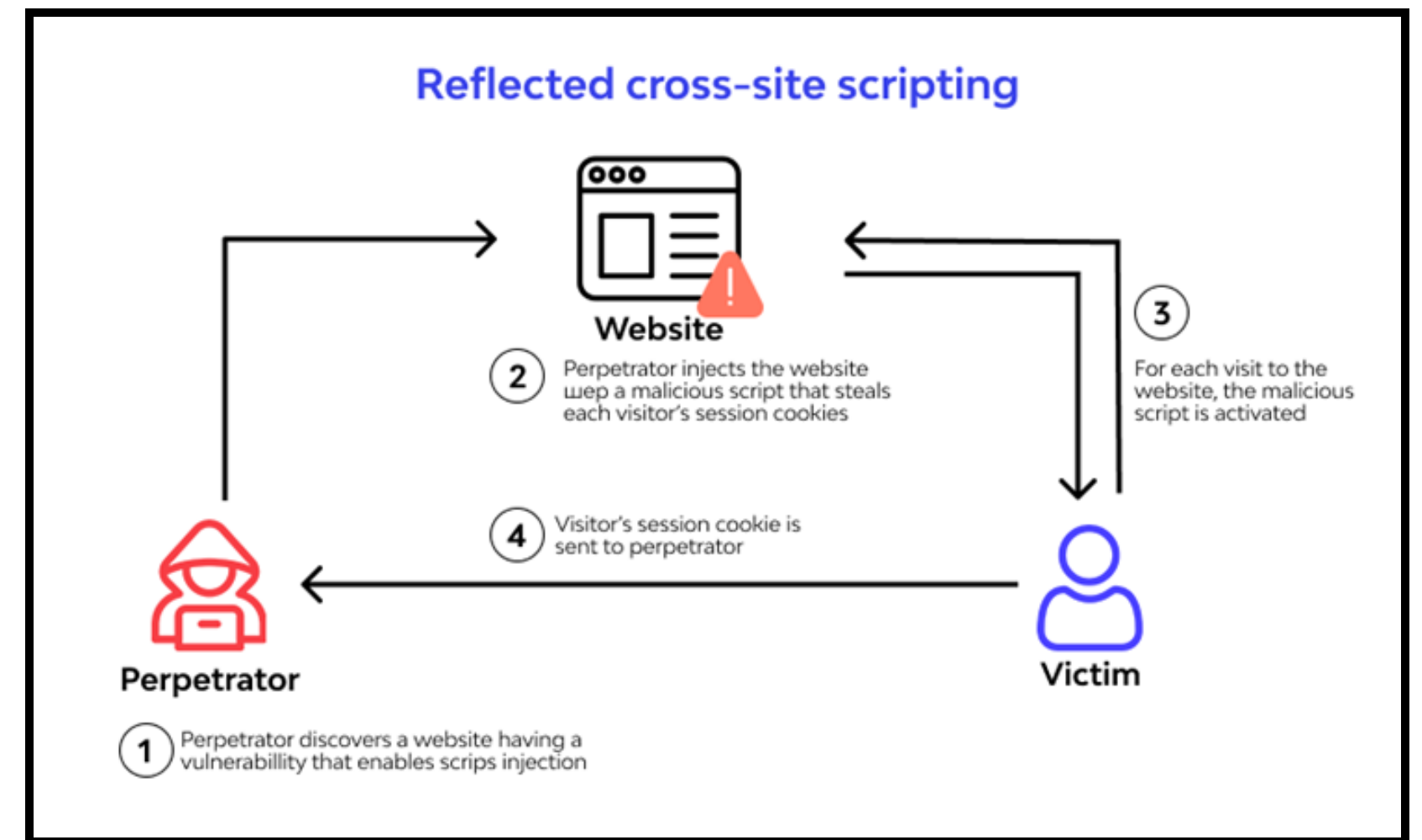
Reflected XSS(반사형 크로스 사이트 스크립팅)란

특정 파라미터 값을 통해서 공격하는 방식으로

검색, 에러메시지, URL등

사용자로부터 입력한 값을 받아 브라우저에게

응답할 때 전송되는 방식



Reflected XSS



Reflected XSS(반사형 크로스 사이트 스크립팅)란

Reflected XSS

Case 1. `http://test.com/search="onerror="location.href=http://attack.com"`

➔ 공격자가 지정한 페이지(`http://attach.com`)로 리다이렉션됨

Case 2. `http://test.com/search=<script>alert(document.cookie)</script>`

➔ 피해자의 쿠키 값이 유출됨

검증, 인코딩 없이 반사된 입력이 응답에 섞여, 사용자가 그 링크를 열 때 해당 사이트의 origin에서 스크립트가 실행되어 피싱유도나 세션, 토큰 탈취로 이어지는 공격

DOM-Based XSS



DOM Based XSS(DOM 기반 크로스 사이트 스크립팅)란

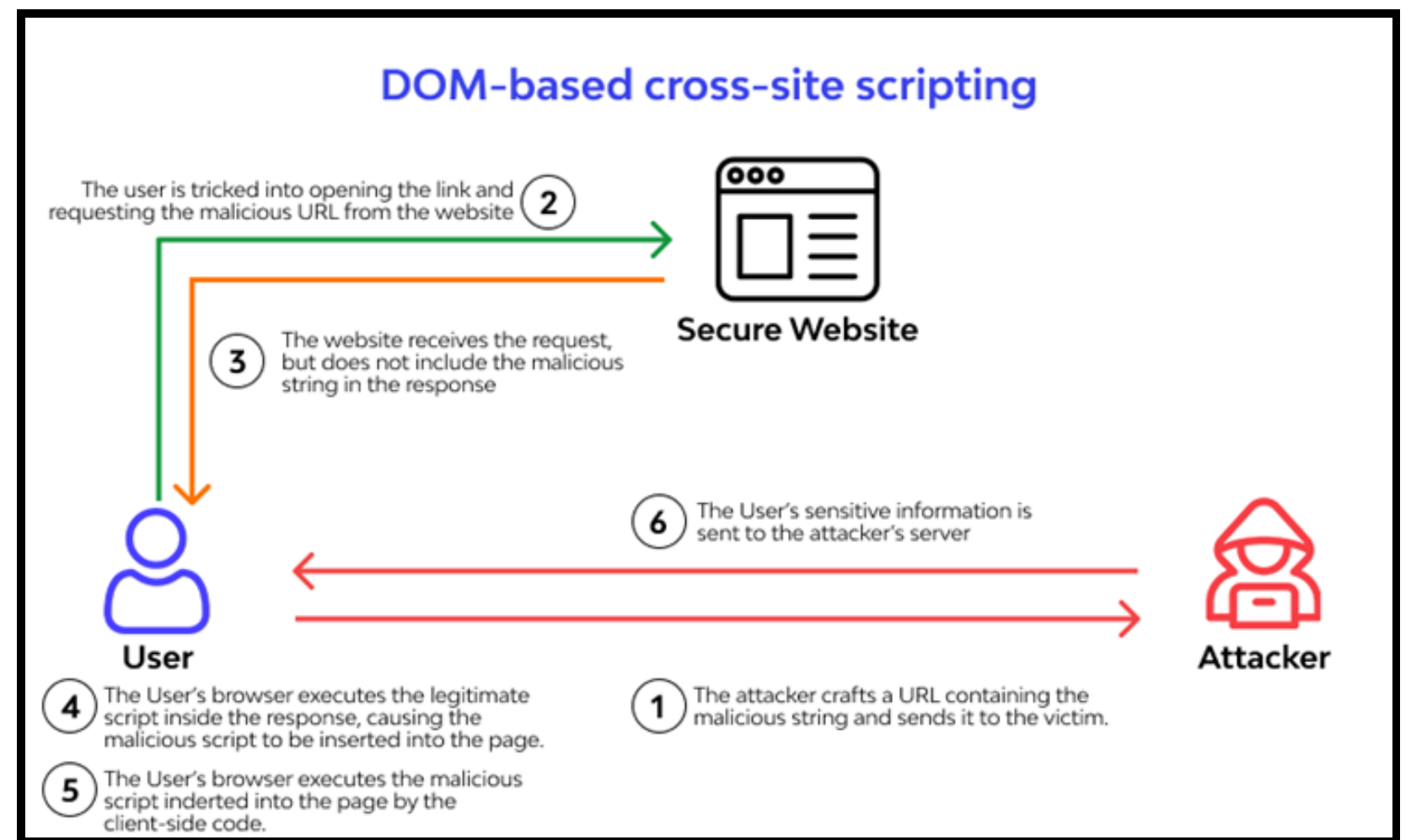
Document Object Model의 약자로

DOM 객체를 포함하는 자바스크립트 등을 이용하여

데이터 접근 시 검증되지 않은 입력 값이

자바스크립트를 통해 삽입되어 발생하는 취약점을

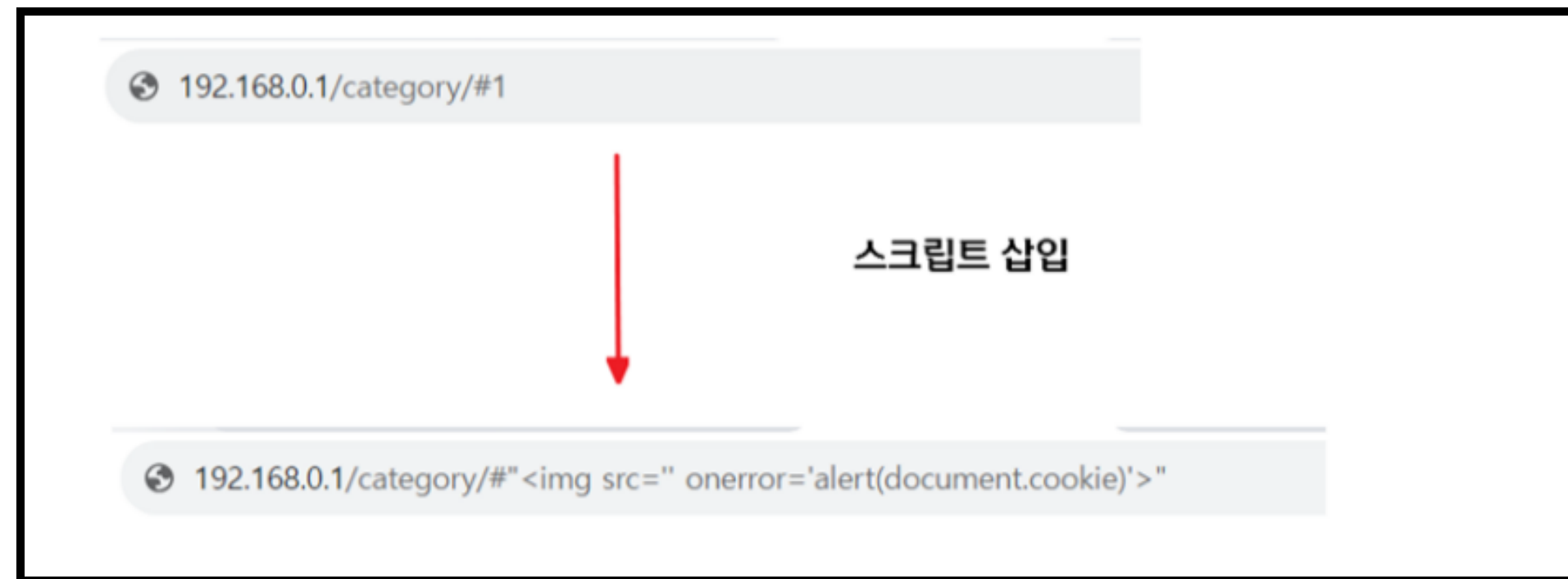
이용하는 방식으로 URL을 통해 사용자를 공격함



DOM-Based XSS



DOM-Based XSS(DOM 기반 크로스 사이트 스크립팅)란



DOM 구조를 이용하여 요소들을 수정하거나 추가하는 등의 동적 행위를 할 때 접근하는 JavaScript에 악성 스크립트를 삽입하여 사용자 측 브라우저에서 악성 스크립트가 실행되도록 하는 공격임

XSS 공격 파급력



- **Stored XSS**

매우 높음

- **Reflected XSS**

높음

- **DOM-Based**

공격 패턴과 피해자 브라우저의 기능에 따라 달라짐

XSS 공격 대응 방안



XSS 공격 대응 방안

- 1. 웹 서버에서 입력 값에 정의된 문자 길이를 제한 또는 검증하여 클라이언트 측에서 실행될 수 있는 스크립트 명령이 삽입되지 않도록 설정
- 2. HTML 태그의 사용이 불필요한 경우 사용자의 입력 값에서 HTML 특수 문자들을 HTML Entity로 변환하여 스크립트를 일반 문자열로 인식되도록 함

Result	Description	Entity Name	Entity Number
	non-breaking space	 	
<	less than	<	<
>	greater than	>	>
&	ampersand	&	&
¢	cent	¢	¢
£	pound	£	£
¥	yen	¥	¥
€	euro	€	€
©	copyright	©	©
®	registered trademark	®	®

XSS 공격 대응 방안



XSS 공격 대응 방안

3. 부득이하게 HTML 태그를 반드시 사용해야할 경우에는 블랙리스트 또는 화이트리스트 방식을 이용해 반드시 사용해야만 하는 특정 태그만 사용할 수 있도록 설정
4. 웹 방화벽(WAF, Web Application Firewall)을 사용하여 비정상적인 데이터가 전송될 경우 차단

실습 과제



실습 과제

1. XSS game 풀고 보고서 작성

<https://xss-game.appspot.com/>

2. 실습 사이트에서 Reflected xss와 Stored xss가 터지는 게시판을 찾고 보고서 작성

<http://sekurity.o-r.kr:409/>

3. Dreamhack xss 1 풀고 보고서 작성

<https://dreamhack.io/wargame/challenges/28>

seKUrity

감사합니다

XSS(Cross Site Scripting)

컴퓨터공학과 25학번 유수민

